

Bài 1. Tìm hiểu các loại mã độc phổ biến

Báo cáo

1. Định nghĩa malware (malicious software)

- Theo Cisco: "Bất kỳ phần mềm xâm nhập trái phép nào do tội phạm mạng phát triển nhằm đánh cắp dữ liệu, gây hư hại hoặc phá hủy máy tính và các hệ thống máy tính".
- Theo McAfee: "Phần mềm độc hại được cài đặt lên thiết bị của bạn mà bạn không hề hay biết".
- Theo Microsoft: "Phần mềm độc hại được thiết kế nhằm phá hoại hoặc đánh cắp dữ liệu nhạy cảm từ các thiết bị, gây ra mối đe dọa cho cả cá nhân lẫn doanh nghiệp".

2. Trình bày, phân tích đặc điểm nổi trội của các nhóm mã độc: virus, worm, trojan, backdoor, adware, botnet, ransomware, stealer, toolkit, dropper.

- Virus: (Theo [Fortinet](#)) Được thiết kế để *lan truyền*. Mục đích: lây lan và phá hoại nặng nề mục tiêu cụ thể. Không có cơ chế tự động lây lan giữa các thiết bị trong mạng.
- Worm: (Theo [CrowdStrike](#)) Loại malware có thể *tự động lây lan, tái tạo rất nhiều bản sao* qua các thiết bị trong mạng (thường là mạng LAN, vì các mạng rộng hơn có firewall khiến cho việc lây lan khó khăn hơn) mà không cần có sự kích hoạt thủ công. Mục đích: lây lan, tái tạo, lây nhiễm nhiều nhất có thể các thiết bị trong mạng.
- Trojan: (Theo [Avast](#)) Loại malware ngụy trang thành/gắn trong các chương trình (trông như) hợp pháp. Không có cơ chế lây lan/tái tạo. Mục đích: thâm nhập vào host, sau đó có thể nghe lén, đánh cắp dữ liệu, hoặc để tải malware khác về.
- Backdoor: (Theo [McAfee](#)) Loại malware xâm nhập vào hệ thống theo cách không chính thống. Hoạt động ngầm, khó phát hiện. Mục đích: truy cập điều khiển từ xa.
- Adware: (Theo [Kaspersky](#)) Phần mềm tự động tạo quảng cáo trên web, mobile. Mục đích: thu lời từ quảng cáo (Pay-per-click (PPC), Pay-per-view (PPV), Pay-per-install (PPI)).
 - Một số loại adware nguy hiểm có thể tạo điều kiện cho malware xâm nhập. Đồng thời adware có thể là spyware (nghe lén lịch sử trình duyệt để hiển thị quảng cáo cá nhân hóa, hoặc bán thông tin đó cho tội phạm).

- Botnet: (Theo [Crowdstrike](#)) Một mạng các thiết bị đã bị nhiễm, được điều khiển bởi botmaster. Mục đích: Các bot trong botnet sẽ tấn công đánh sập mạng, chèn malware vào, thu thập dữ liệu, hoặc thực thi các tác vụ nặng CPU nhằm cản trở hoạt động của mạng đó. Có 2 mô hình botnet phổ biến xoay quanh botmaster, C2 server, bots :
 - Tập trung: Botmaster --điều khiển--> C2 servers --điều khiển--> Bots của từng C2 server. Nhược điểm: Cả botnet/nhánh botnet sẽ hỏng nếu một C2 server bị hỏng. Có 2 loại giao tiếp phổ biến của C2 server:
 - IRC: Internet Relay Chat. Các bots kết nối đến các IRC server và chờ lệnh.
 - HTTP: botmaster dùng HTTP để gửi command. Các bots sẽ định kỳ truy cập vào HTTP server để nhận lệnh. Ưu điểm của HTTP server là hoạt động sẽ trông giống lưu lượng web thông thường.
 - Peer-to-Peer: Nhược điểm: khó triển khai và kiểm soát.
 - Các bots chia sẻ lệnh, thông tin với nhau, không giao tiếp trực tiếp với C2 servers.
 - Mỗi bot đều đóng vai trò là client và server.
- Ransomware: (Theo [Cloudflare](#)) Loại malware nhắm vào các dữ liệu nhạy cảm của nạn nhân, khóa các dữ liệu đó lại để đe dọa đòi tiền. Mục đích: đòi tiền.
- Stealer: (Theo [Malwarebytes](#)) Loại malware duy trì sống trong thiết bị đã bị nhiễm nhằm đánh cắp dữ liệu (điển hình là creds) để gửi về cho kẻ tấn công. Mục đích: đánh cắp creds.
- Rootkit: (Theo [Crowdstrike](#)) Là 1 nhóm/bộ gồm nhiều module ưu tiên sự ẩn náu, khi được kích hoạt sẽ ngầm kiểm soát máy nạn nhân, cài đặt backdoor hoặc đưa vào host thêm malware. Mục đích: kiểm soát/nhiều malware hoạt động theo module, tấn công ở nhiều phương diện.
 - User-mode rootkit thường ở dạng file DLL, từ đó malware sẽ load DLL đó vào tất cả các tiến trình đang chạy để kiểm soát.
 - Kernel-mode rootkit thường là driver, được load như 1 phần của kernel.
- Dropper: (Theo [Kaspersky](#)) Được thiết kế để đưa malware vào host. Bản thân dropper không chứa chức năng gây hại, mà chỉ phục vụ việc tải malware khác về thông qua payload của nó. Có nhiều dropper thuộc loại Trojan. Ví dụ điển hình: keygen.
 - Khác biệt so với Trojan: Trojan khi xâm nhập sẽ tấn công host, còn dropper chỉ phục vụ tải malware khác về, việc tấn công là do malware được tải về sẽ thực hiện.

3. Mẫu malware thực tế/chiến dịch tấn công

- Virus: Win95/CIH (theo [Microsoft](#), [Kaspersky](#))
 - Hành vi:
 - Gắn bản thân vào các vùng trống giữa các section của file PE nhằm khiến file không tăng kích thước
 - Đánh dấu một vùng cụ thể của file để không lặp lại việc infect.
 - Gắn startup routine vào vùng trống ở PE header

- Vá địa chỉ entry của chương trình host để chỉ đến startup routine.
 - Startup routine sẽ cấp bộ nhớ bằng PageAllocate VMM call rồi copy nó cùng các đoạn code khác của CIH vào đó.
 - Được thực thi ở mức nhân, can thiệp vào hoạt động mở file để lây nhiễm file thực thi được chạy.
 - Vào các ngày cố định, kích hoạt payload có chức năng ghi đè ổ boot, flash BIOS.
- Căn cứ phân loại: Chỉ được kích hoạt nếu chương trình host được chạy, và chỉ có thể lây lan thụ động bằng cách chờ có file được mở, không chủ động lây lan sang các thiết bị khác qua mạng.
- Worm: Morris (theo [Kaspersky](#), [MIT](#))
 - Hành vi: Lây lan bằng cách khai thác các lỗ hổng trên một phiên bản UNIX:
 - Sendmail debug mode: Mở kết nối SMTP rồi lợi dụng tính năng gửi mail với phần 'người nhận' là một chương trình. Trong trường hợp morris worm, phần 'người nhận' là một lệnh để chuyển tiếp nội dung email vào một trình dịch lệnh. Nội dung email là một script tạo chương trình C đóng vai trò "grappling hook" - chuyển tiếp các module và lệnh từ host để thực thi nó.
 - Finger daemon bug: Khi kết nối với fingerd của máy nạn nhân, thực hiện buffer overflow vì fingerd không kiểm tra kích thước input.
 - Rexec and Passwords: Khai thác /etc/passwd và bruteforce để lấy quyền dùng remote execution protocol.
 - Rsh and Trust: Các file như /etc/hosts.equiv hoặc .rhosts chứa danh sách các host được hệ thống tin tưởng. Morris worm lợi dụng cơ chế này: từ một máy đã bị nhiễm, nó dùng quyền root để mở một cổng mạng tin cậy và truyền tên người dùng tới máy nạn nhân. Máy nạn nhân sẽ tự động cho phép kết nối thẳng vào trình thông dịch lệnh mà không cần hỏi mật khẩu, vì nó xác thực dựa trên địa chỉ IP thay vì danh tính người dùng.
 - Căn cứ phân loại: Tự chủ hoạt động và lây lan qua các kênh kết nối có thể, không cần chương trình host hay can thiệp từ bên ngoài.
- Trojan: AppleJus (theo [Microsoft](#), [MITRE](#)). Được sử dụng bởi nhóm APT [Lazarus Group](#), hoạt động trên MacOS theo nhiều giai đoạn.
 - Hành vi:
 - Threat actor đã đầu tư để biến các nền tảng giao dịch tiền ảo giả trông như hợp pháp, thường bằng cách biến tưởng nền tảng giao dịch tiền ảo mã nguồn mở để xây dựng các installer được cấy trojan.
 - Ở phiên bản đầu tiên của AppleJus, installer là các file DMG, PKG trông như hợp pháp, thường đi kèm cả chữ ký/chứng chỉ số để bypass Gatekeeper (Apple).
 - Khi chạy installer, một post-install script sẽ giúp tải file .plist từ /Resources của AppleJus về /System/Library/LaunchDaemons/ hay /Library/LaunchDaemons/, từ đó thực thi file .plist đã tải như LaunchDaemon, giúp thiết lập persistence.

- Sau đó, kết nối đến C2 server nhằm đánh cắp dữ liệu. Sử dụng các biện pháp như hash để đảm bảo payload ở giai đoạn sau chỉ được tải về bởi máy đã bị nhiễm giai đoạn đầu. Mã hóa dữ liệu trước khi gửi về server.
 - Căn cứ phân loại: Malware được tải về từ một chương trình gốc (installer) trông như hợp pháp. Cần có sự kích hoạt thủ công (người dùng chạy installer). Mục tiêu nhắm vào persistence và đánh cắp dữ liệu cẩn thận. Không nhắm vào tự động lây lan, tái tạo diện rộng.
- Backdoor: SUNBURST (theo [GTI](#), [GTI](#)). Được sử dụng bởi nhóm APT29.
 - Hành vi:
 - Được trojan-hóa trong SolarWinds.Orion.Core.BusinessLayer.dll, một plug-in có chữ ký điện tử của phần mềm SolarWinds Orion. Xâm nhập được vào nhiều tổ chức thông qua bản cập nhật của phần mềm này.
 - Bản cập nhật là một file Windows Installer Patch tiêu chuẩn, nén các tài nguyên cần thiết cho cập nhật và chứa plugin bị trojan-hóa. Khi bản cập nhật được chạy, plugin đó sẽ được chạy bởi file thực thi tiêu chuẩn của SolarWinds.
 - Trước khi thực thi, kiểm tra tên tiến trình chạy nó để xác nhận không trong sandbox. Ngoài ra, có blocklist và các biện pháp vô hiệu hóa các đối tượng trong blocklist, và các biện pháp phát hiện công cụ forensics, AV.
 - SUNBURST chỉ thực thi sau khi kiểm tra xác nhận lần ghi gần nhất của .NET assembly SolarWinds.Orion.Core.BusinessLayer.dll vào filesystem cách đó tối thiểu 12-14 ngày.
 - SUNBURST kết nối đến C2 trung gian. Sử dụng các biện pháp tạo subdomain có chứa thông tin về máy nạn nhân. Từ đó, C2 trung gian chuyển hướng SUNBURST đến máy chủ C2 cuối.
 - Trong chế độ thụ động, giao tiếp với C2 trung gian bằng DNS để nhận lệnh về trạng thái (ngủ/hành động). Trong chế độ hành động, giao tiếp với máy chủ C2 cuối bằng HTTP để nhận các lệnh chi tiết về kiểm soát, truy cập máy nạn nhân.
 - Ngụy trang lưu lượng mạng thành giao thức Orion Improvement Program (OIP), lưu trữ kết quả trình sát vào các file config hợp pháp.
 - Căn cứ phân loại:
 - Ẩn náu cẩn trọng, đặc biệt có thời gian ngủ đông ban đầu lên tới 2 tuần.
 - Nhận lệnh từ C2 server, không tự ý hành động, lây lan, tái tạo.
 - Có quyền ngầm truy cập và điều khiển hệ thống.
- Adware: VisualDiscovery (theo [FTC](#)). Phần mềm sản xuất bởi Superfish, Inc. được Lenovo cài sẵn trong laptop từ tháng 8 năm 2014.
 - Hành vi:
 - Hiện thị pop-up ads từ các đối tác bán lẻ của Superfish mỗi khi người dùng di chuột vào một sản phẩm tương tự khi duyệt web.
 - Đóng vai trò như một man-in-the-middle giữa trình duyệt và website.
 - Truy cập được vào tất cả thông tin cá nhân nhạy cảm của người dùng khi hoạt động internet.

- Để hiển thị pop-up trên cả các website https, VisualDiscovery thay thế chữ ký điện tử của các website đó bằng của VisualDiscovery, không quan tâm các website đó có chữ ký gốc uy tín hay không.
 - Căn cứ phân loại: Không có cơ chế lây lan, tái tạo. Chức năng chính là hiển thị quảng cáo.
- Botnet: Mirai (theo [Cloudflare](#), [CIS](#)). Lây nhiễm trên các thiết bị thông minh chạy CPU ARC. Mục đích ban đầu: DDoS đánh sập các server Minecraft đối thủ.
 - Hành vi:
 - Máy đã bị nhiễm quét internet để tìm các thiết bị IoT chạy CPU ARC. ARC sử dụng 1 phiên bản Linux rút gọn, Mirai có thể đăng nhập vào thiết bị nếu cặp username-password mặc định chưa đổi. Kết hợp với bruteforce. Các phiên bản mới sẽ khai thác các lỗ hổng mới hơn.
 - Báo cáo lại cho server nếu tìm thấy mục tiêu. Server gửi payload lây nhiễm mục tiêu.
 - Căn cứ phân loại: Mục đích lây nhiễm, chiếm quyền kiểm soát nhiều thiết bị nhất có thể (dễ nhầm: thiết bị IoT) để thực hiện DDoS.
- Ransomware: DARKSIDE (theo [GTI](#), [PaloAlto](#)). Là một RaaS được quảng bá trên các diễn đàn tiếng Nga. Nhóm actor tìm kiếm đối tác, thu phí phần trăm với khoản tiền chuộc thu được từ nạn nhân của đối tác, rất hung hãn trong việc gây áp lực đòi tiền. DARKSIDE được tùy chỉnh cho phù hợp với từng mục tiêu.
 - Hành vi: Chức năng chính là mã hóa file trên các ổ đĩa cứng như các file được chia sẻ trên mạng nội bộ.
 - Setup mã hóa: Tạo một file extension bán-ngẫu nhiên dựa trên địa chỉ MAC của máy, hoặc, ở các phiên bản mới hơn, sử dụng MachineGuid. File extension bao gồm 8 ký tự hex viết thường, format `<ransom_ext>`.
 - Kỹ thuật chống phục hồi: Làm trống Recycle Bins và xóa Volume Shadow Copies.
 - Đánh cắp dữ liệu: bằng các thủ đoạn như truyền qua SFTP sử dụng Rclone.
 - Căn cứ phân loại: Không có cơ chế lây lan/tái tạo. Mục đích chính là mã hóa và đánh cắp dữ liệu để đòi tiền. Hành động mạnh bạo.
- Stealer: RedLine (theo [Microsoft](#)). Chạy trong Common Language Runtime của .NET framework. Không có phương pháp lây nhiễm cụ thể, thay đổi tùy theo chiến dịch tấn công. Một số con đường lây nhiễm: fork repo malware có mật khẩu; malvertising chuyển hướng đến các trang giả mạo cập nhập các phần mềm hợp pháp; hoặc trojan-hóa trong các installer.
 - Hành vi:
 - Process hollowing: Khi loader chạy, nó tạo một tiến trình ở trạng thái suspend cho một file thực thi hợp pháp, thường là *Regsvcs.exe*, *vbc.exe*. Loader cấp bộ nhớ cho tiến trình, viết payload của RedLine vào đó, rồi resume tiến trình.
 - Các tham số cho việc thực thi được lưu mã hóa trong class tên Arguments. Bao gồm địa chỉ IP của C2 server, khóa mã hóa dùng cho đánh cắp dữ liệu...

- Có các biến thể được bảo vệ bởi VMProtect: chuyển bytecode gốc thành các lệnh asm được thông dịch tại runtime, gây khó khăn cho phân tích tĩnh.
 - Trích xuất dữ liệu và creds từ trình duyệt, FTP clients, và các phần mềm VPN. Với Chromium, điều hướng đến Local State file trong thư mục user profile để tìm master key. Gọi hàm Windows CryptUnprotectData để giải mã master key. Copy cơ sở dữ liệu SQLite rồi dùng master key để giải mã các creds trong đó. Dùng các kỹ thuật tương tự với credit card entries và session cookies trong cơ sở dữ liệu Web Data và Cookies.
 - Nén các dữ liệu thu thập được để chuẩn bị cho đánh cắp. Thu thập metadata từ máy nạn nhân để phục vụ đánh giá giá trị của dữ liệu thu được.
 - Kết nối C2 được triển khai bằng Windows Communication Foundation, dùng giao thức net.tcp để thiết lập một kênh truyền nhị phân persistent. Việc truyền thông được cấu trúc thành nhiều endpoint để truyền các dữ liệu khác nhau.
- Căn cứ phân loại: Không có cơ chế lây lan/tái tạo. Hoạt động mục đích chính để đánh cắp thông tin trên từng thiết bị.
- Rootkit: Sony BMG XCP's DRM/Sony rootkit (theo [Mark Russinovich](#)). Sony BMG cài đặt phần mềm DRM (Digital Rights Management) vào bộ chơi nhạc độc quyền của họ.
 - Hành vi:
 - Tải các driver .sys nhằm can thiệp vào ổ CD-ROM.
 - Vá các mục (entries) trong bảng dịch vụ hệ thống của kernel để chiếm quyền và thực thi ở kernel-mode.
 - Ẩn tất cả các file bắt đầu với "\$sys\$" (ký hiệu đánh dấu tên các file thuộc rootkit).
 - \$sys\$DRMServer.exe khi thực hiện sẽ gọi 1 dịch vụ duy trì chạy trong nền, quét và truy xuất thông tin về file thực thi tương ứng với các tiến trình đang chạy.
 - Các driver của rootkit được cấu hình là boot-start driver hoặc thuộc HKLM\System\CurrentControlSet\Control\SafeBoot subkeys.
 - Căn cứ phân loại:
 - Không lây lan/tái tạo. Tập trung vào ẩn náu và kiểm soát hệ thống.
- Dropper: NullMixer (theo [Kaspersky](#)). Lây nhiễm từ các website tải phần mềm lậu.
 - Hành vi:
 - Được kích hoạt thủ công khi người dùng giải nén và chạy installer như win-setup-i864.exe. File này drop và chạy setup_installer.exe - bản chất là một 7z Setup SFX được bọc trong file .exe.
 - setup_installer.exe drop hơn chục file malware. Bộ thực thi của NullMixer hardcode tên các file đó và chạy bằng cmd.exe.
 - Cố gắng thay đổi cài đặt WinDefend bằng powershell.
 - Sau khi tất cả các file malware đã được chạy, bộ thực thi của NullMixer khởi tạo kết nối đến C2 server để thông báo tải malware thành công. Các malware hoạt động độc lập từ đây.

- Căn cứ phân loại: Bản thân NullMixer chỉ đóng vai trò drop các malware và liên lạc với C2 server. Các file malware hoạt động độc lập.